



中国互联网安全大会



360互联网安全中心

ISC
2015

数据驱动安全

2015 中国互联网安全大会
China Internet Security Conference

开源代码安全之痛

主要内容

- 1、开源软件安全事件带来的思考
- 2、开源项目检测计划和实例分析
- 3、软件代码安全解决之道

开源软件安全事件

OpenSSL是一个开源的安全套接字层密码库，2014年曝光重大安全漏洞Heartbleed。攻击者通过构造异常的数据包进行攻击，获取用户敏感信息。

ElasticSearch是全文搜索引擎开源代码项目。2014年和2015年分别爆出远程任意命令执行漏洞。攻击者可利用远程任意命令执行漏洞获取主机最高权限。

Struts2是Apache软件基金会赞助的一个开源项目，近年来频繁爆发安全漏洞。影响国内电商、银行、运营商等诸多大型网站和为数众多的政府网站。

Tomcat是一个免费的开源的Servlet容器，2014年爆出严重的安全漏洞，其中包括多个DoS漏洞和信息泄露漏洞。

开源软件的思考

基础原材料

2010年，Gartner采访了来自11个国家的547位公司负责人，在被调查的公司当中超过一半采用了开源软件作为其IT战略的组成部分。

安全性

2012年，Aspect Security和Sonatype公开的一份调查报告显示，最受欢迎的31个开源项目中，其不安全的版本被下载了超过4,600万次。

法律风险

开源不等于免费，开源软件许可协议背后的条条框框你清楚吗？

主要内容

1、开源软件安全事件带来的思考

2、开源项目检测计划和实例分析

3、软件代码安全解决之道

开源项目检测计划

开源项目检测计划（www.codesafe.cn）是由360代码卫士团队发起，针对开源项目进行的一项公益安全检测计划，旨在让广大开发者关注和了解开源代码安全问题，提高软件安全开发意识和技能。

注：开源项目检测计划使用的检测工具是360自主研发的源代码检测引擎“代码卫士”。

[收藏本站](#)

愿我们的代码更有生命力！

[登录 - 注册](#)[帐户管理](#)[常见问题](#)[联系我们](#)代码卫士
codesafe[首页](#)[我的检测](#)[安全资讯](#)[开源项目检测计划](#)

每段代码都需要你的“呵护”

带上你的代码来这里“体检”吧！

```
StringBuffer sqlStatement = new  
Input input = new Input  
ec.addElement(input);  
  
Element b = ECSFactory.makeButton  
ec.addElement(b);  
  
Connection connection = DatabaseUtilit
```

JAVA开源项目检测计划

已检测 **1010** 个开源项目

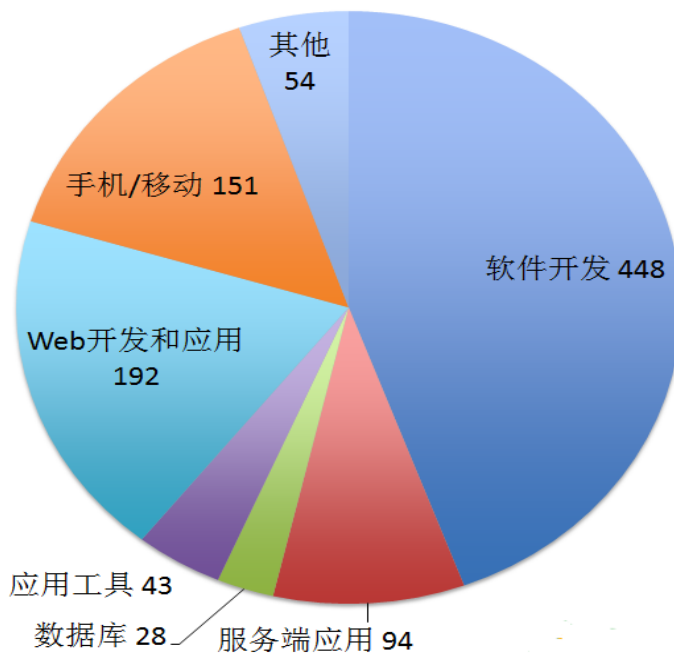
已检测到 1649801 个安全缺陷

[我要检测开源代码](#)

你也可以[上传私人代码](#)进行检测

开源项目检测计划—开源项目检测概况

开源项目分类分布

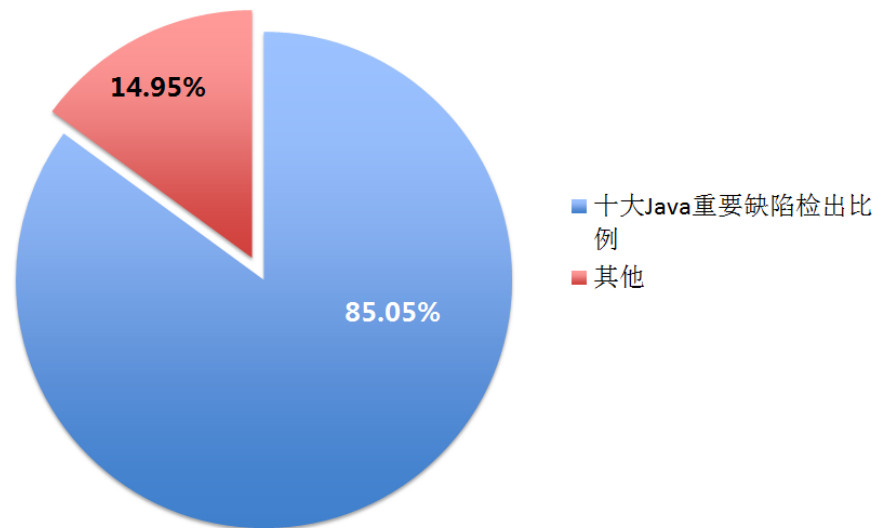


目前已检测1010个Java开源项目，检测代码总量65,800,663行，总计发现1,646,035个源代码缺陷，缺陷密度25.02个/千行。

开源项目检测计划—十大JAVA严重缺陷统计

十大 Java 重要缺陷	缺陷总数 (个)
SQL 注入	2491
跨站脚本	5011
路径遍历	17852
密码管理	21273
HTTP 消息头注入	3106
命令注入	765
资源注入	12555
资源未释放	75450
系统信息泄露	113429
跨站请求伪造	10157
总计	262089

十大Java重要缺陷检出比例



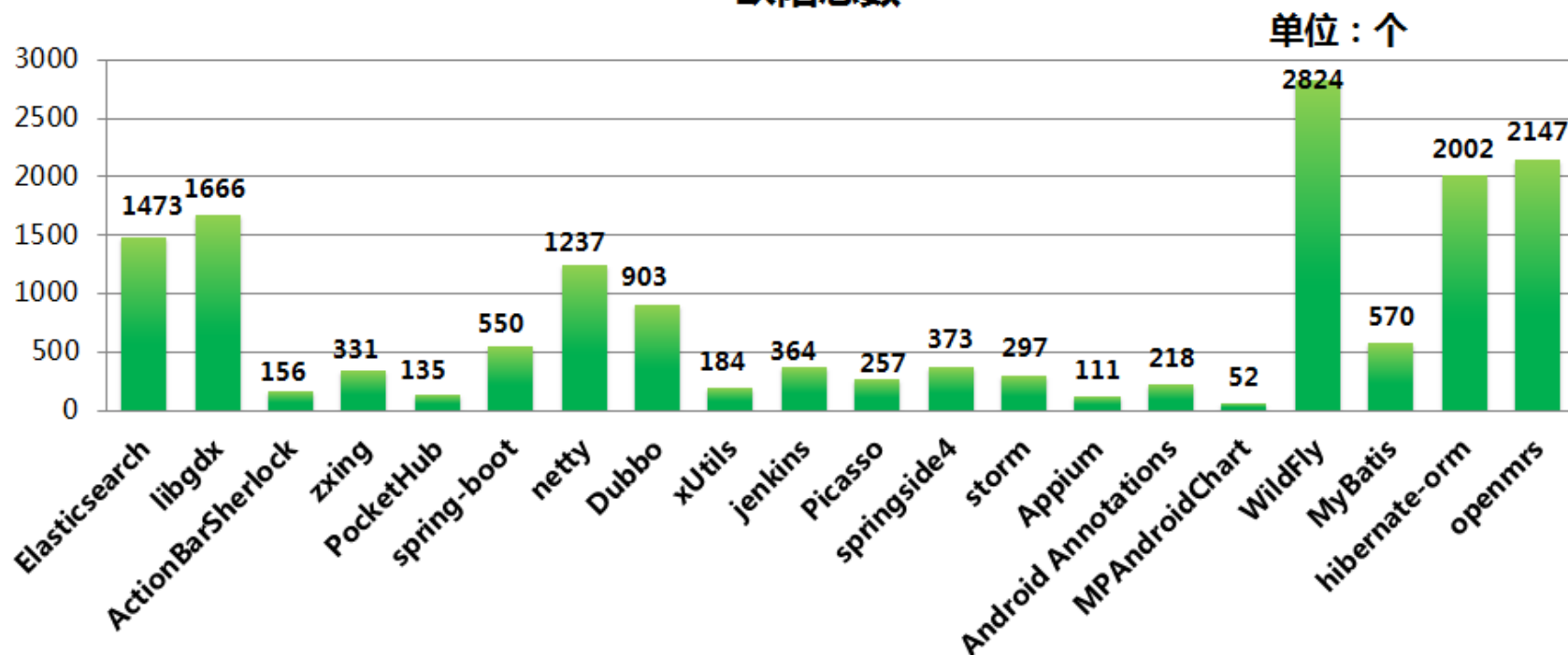
开源项目检测计划—20个流行项目

序号	项目名称	Fork	Star	Watch	版本号	缺陷总数
1	Elasticsearch	4132	12758	1303	1.5.1	1473
2	libgdx	4100	7008	936	1.5.0	1666
3	ActionBarSherlock	4096	7029	853	4.4.0	156
4	zxing	3854	6116	813	3.1.0	331
5	PocketHub	3441	6950	1054	1.9.0	135
6	spring-boot	3020	2903	501	1.3.0.M1	550
7	netty	2655	5223	813	4.0.24.Final	1237
8	Dubbo	2459	2321	758	2.5.3	903
9	xUtils	2288	3046	546	2.6.14	184
10	jenkins	2119	4532	577	1.616	364
11	Picasso	2042	7278	682	2.5.2	257
12	spring-side4	2038	2757	747	4.2.3.GA	373
13	storm	1748	8686	1174	0.9.0.1	297
14	Appium	1744	2600	464	1.4.10	111
15	Android Annotations	1739	6024	617	3.3.2	218
16	MPAndroidChart	1731	5194	395	2.0.8	52
17	WildFly	1432	1439	172	10.0.0.Beta1	2824
18	MyBatis	1401	1657	409	3.3.0	570
19	hibernate-orm	1172	1374	201	5.0.0.CR4	2002
20	openmrs	1161	234	82	1.9.1	2147

开源项目检测计划—20个流行项目缺陷总数统计

流行项目缺陷总数

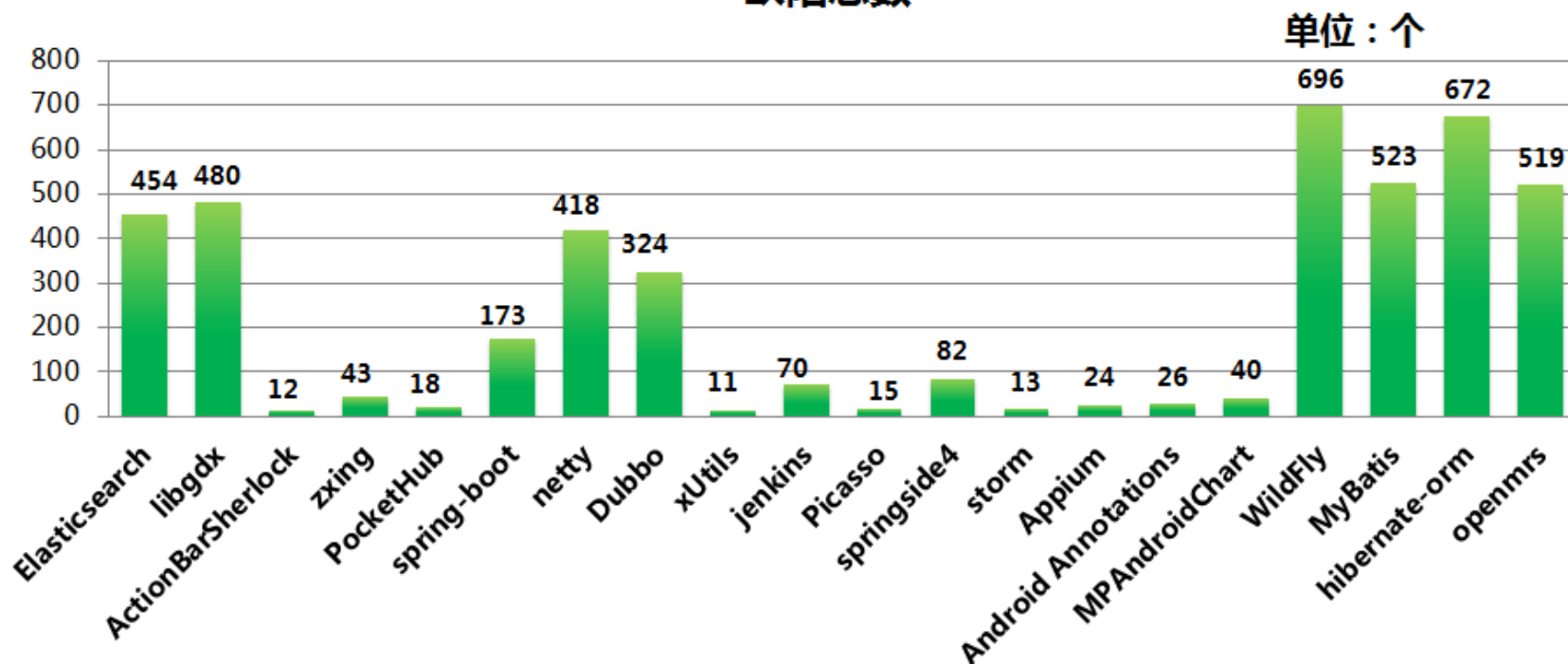
■ 缺陷总数



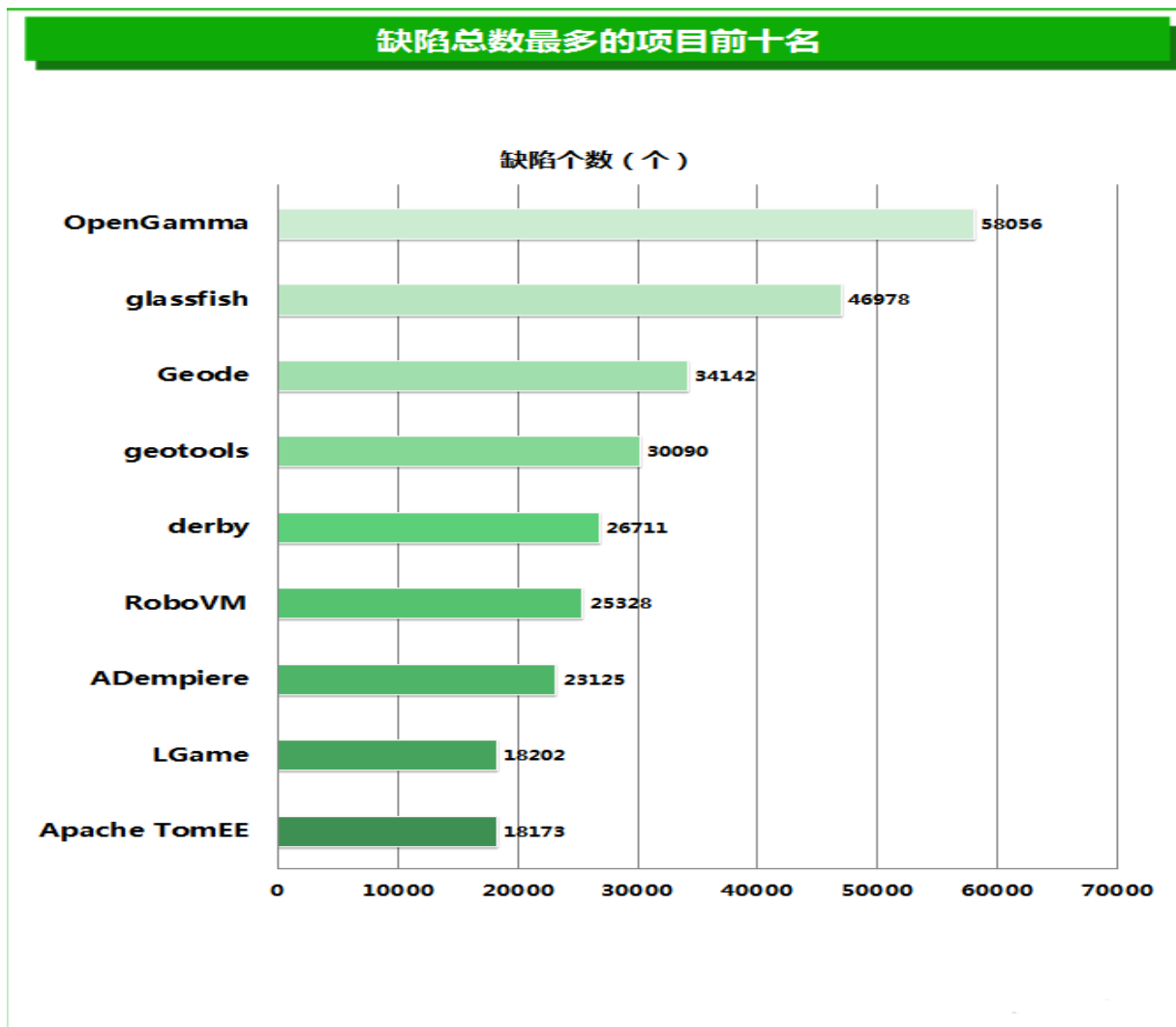
开源项目检测计划—20个流行项目十大JAVA重要缺陷数量统计

流行项目十大Java重要缺陷总数

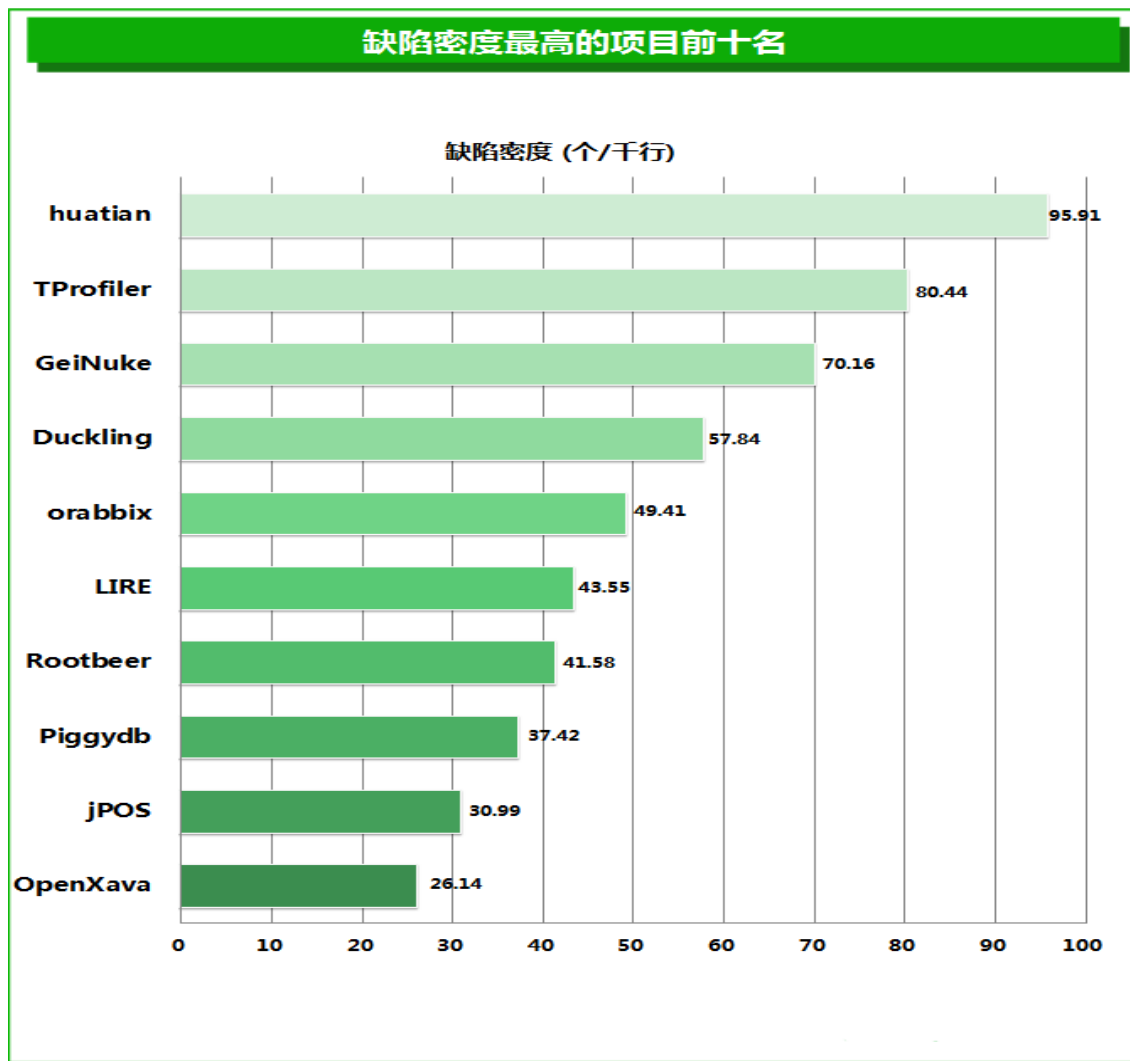
■ 缺陷总数



开源项目检测计划—缺陷数量TOP 10项目



开源项目检测计划—缺陷密度TOP 10项目



实例分析1—某开源论坛项目XSS漏洞

```
14 <form id="create_form" action="${baseUrl!}/topic/save" method="post">
15     <select name="sid" id="sid" class="form-control" style="width: 20%; margin-bottom: 5px;">
16         <#list sections as section>
17             <option value="${section.id}">${section.name}</option>
18         </#list>
19     </select>
20     <input type="text" placeholder="标题字数10字以上" id="title" name="title" class="form-control"
21     <input type="text" placeholder="原文地址（原创可不写）" id="original url" name="original url" cla
22     <div id="content" style="margin-bottom: 5px;"><textarea name="content"></textarea></div>
23     <input type="button" onclick="submitForm()" value="提交" class="btn btn-primary">
24 </form>
```

```
108 String content = getPara("content");
109 String original_url = getPara("original_url");
110 Topic topic = new Topic();
111 topic.set("id", StrUtil.getUUID()) 109
112     .set("in_time", new Date()) 110
113     .set("s_id", sid) 111
114     .set("title", title)
115     .set("content", content)
```

```
public String getPara(String name) {
    return request.getParameter(name);
}
```

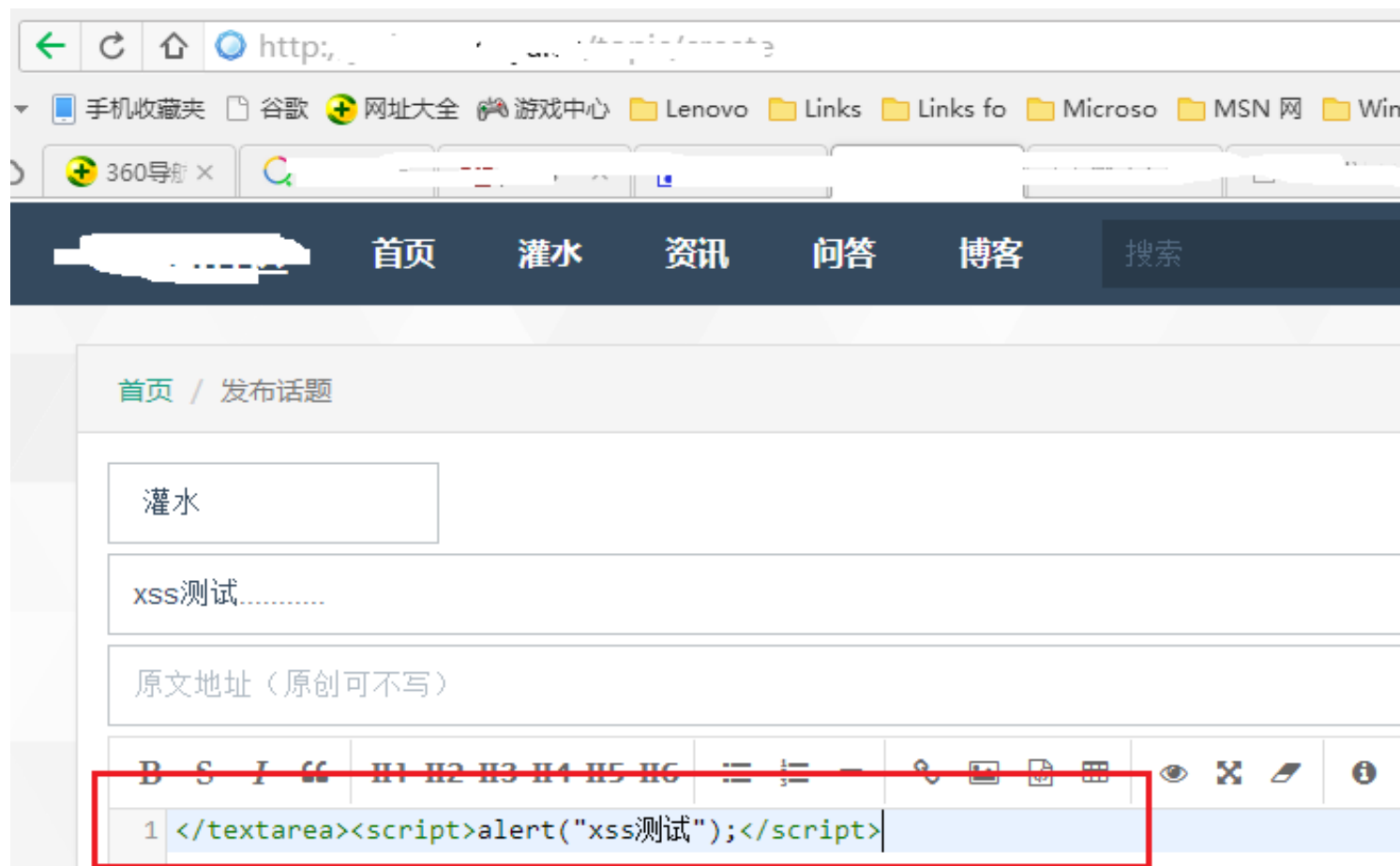
```
24 Topic topic = Topic.me.findByIdWithUser(id);
25 if (topic != null) {
26     List<Reply> replies = Reply.me.findByTid(id);
27     setAttr("topic", topic);
```

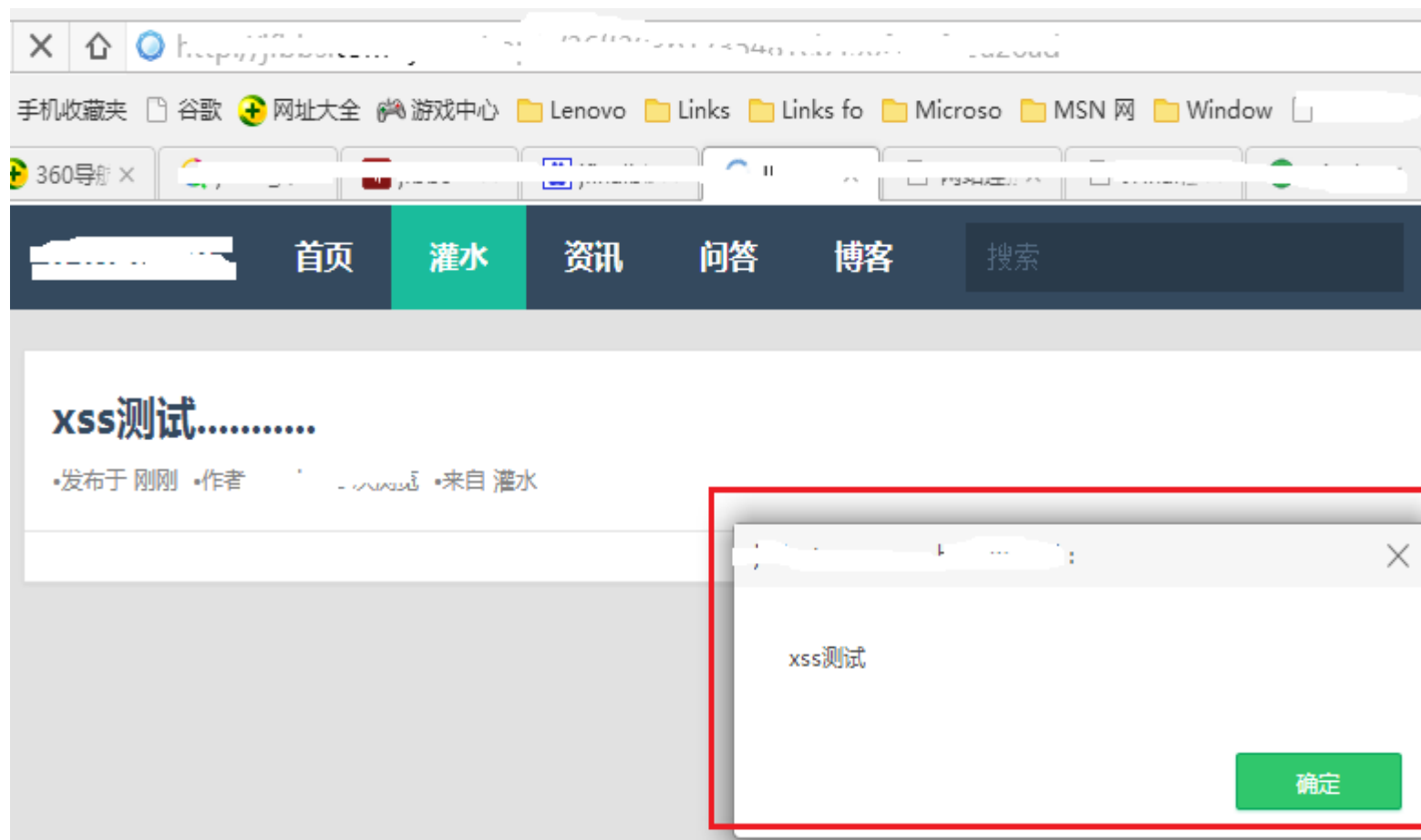
```
74 public Controller setAttr(String name, Object value) {
75     request.setAttribute(name, value);
76     return this;
77 }
--
```

```
62 <div class="panel-body" style="border-top: 1px #E5E5E5 solid; padding-top: 10px">
63     <div id="topic_content">
64         <textarea id="_topic_content" style="display: none;">${topic.content!}</textarea>
65     </div>
66     <#if topic.reposted?? && topic.reposted == 1>
```



XSS





实例分析2—某开源论坛项目SQL注入漏洞

```
String sort = ParamUtil.getParameter(request, "sort");
String order = ParamUtil.getParameter(request, "order");
if (sort.length() == 0) sort = "ThreadLastPostDate";
if (order.length() == 0) order = "DESC";

int offset = 0;
int rows = MVNForumConfig.ROWS_IN_THREADS;

try {
    offset = ParamUtil.getParameterInt(request, "offset");
} catch (BadInputException ex) {}

try {
    rows = ParamUtil.getParameterInt(request, "rows");
} catch (BadInputException ex) {}

int totalThreads = ThreadWebHelper.getNumberOfThreads_inForum(forumID);
if (offset > totalThreads) {
    throw new BadInputException("The offset is not allowed to be greater than total rows.");
}

Collection beans = ThreadWebHelper.getThreads_inForum_withSortSupport_limit(forumID, offset, rows, sort, order);

public static String getParameter(HttpServletRequest request, String param) {
    String ret = request.getParameter(param);
    if (ret == null) ret = "";
    return ret.trim();
}
```

```
: Collection getThreads_inForum_withSortSupport_limit(int forumID, int offset, int rowsToReturn, String sort, String order)
    IllegalArgumentException, DatabaseException, BadInputException {
    s.getDatabaseType() == DBUtils.DATABASE_MYSQL) {
    net.myvietnam.mvnplugin.mvnforum.db.ThreadWebHelper getBeans_inForum_withSortSupport_limit_mysql(forumID, offset, rowsToReturn, sort,
    (DBUtils.getDatabaseType() == DBUtils.DATABASE_NOSCROLL) {

protected static Collection getBeans_inForum_withSortSupport_limit_mysql(int forumID, int offset, int rowsToReturn, String sort,
    throws IllegalArgumentException, DatabaseException, BadInputException {

798 //sql.append(" ORDER BY ThreadCreationDate DESC ");
799 sql.append(" ORDER BY " + sort + " " + order); // ColumnName, ASC
800 sql.append(" LIMIT ?, ?");
801 try {
802     connection = DBUtils.getConnection();
803     statement = connection.prepareStatement(sql.toString());
804     statement.setInt(1, forumID);
```

SQL注入

实例分析3—某开源流媒体解析工具包类型混淆漏洞

- 该开源软件用于解析RTMP流媒体，支持RTMP协议及RTMPT/RTMPS/RTMPE等各类变种。
- 该开源软件及其库文件被广泛用于各种视频及音频流解决方案，如FFmpeg(被多款音视频播放器所使用)、SMPlayer(ubuntu14.x默认自带)、Mplayer等。
- 该开源软件类型混淆漏洞的产生是由于对union的不当使用，导致double数据的高八位被当作指针进行处理，进而导致对非法内存地址的访问。

```
12909: HandleInvoke(RTMP *_r, const char *body, unsigned int nBodySize)
12910: {
12911:     AMFObject obj;
12912:     AVVal method;
12913:     double txn;
12914:     int ret = 0, nRes;
12915:     if (body[0] != 0x02) /* make sure it is a string method name we start with */
12916:     {
12917:         RTMP_Log(RTMP_LOGWARNING, "%s, Sanity failed. no string method in invoke packet",
12918:             __FUNCTION__);
12919:         return 0;
12920:     }
12921:
12922:     nRes = AMF_Decode(&obj, body, nBodySize, FALSE);

01174:     }
01175:
01176:     nRes = AMFProp_Decode(&prop, pBuffer, nSize, bDecodeName);
01177:     if (nRes == -1)
01178:         bError = TRUE;

00653:     switch (prop->p_type)
00654:     {
00655:     case AMF_NUMBER:
00656:         if (nSize < 8)
00657:             return -1;
00658:         prop->p_vu.p_number = AMF_DecodeNumber(pBuffer);
00659:         nSize -= 8;
00660:         break;
00661:     case AMF_BOOLEAN:
00662:         if (nSize < 1)
00663:             return -1;
00664:         prop->p_vu.p_number = (double)AMF_DecodeBoolean(pBuffer);
00665:         nSize--;
00666:         break;
00667:     case AMF_STRING:
00668:     {
00669:         unsigned short nStringSize = AMF_DecodeInt16(pBuffer);
00670:
00671:         if (nSize < (long)nStringSize + 2)
00672:             return -1;
00673:         AMF_DecodeString(pBuffer, &prop->p_vu.p_aval);
00674:         nSize -= (2 + nStringSize);
00675:         break;
00676:     }
00677:     case AMF_OBJECT:
00678:     {
00679:         int nRes = AMF_Decode(&prop->p_vu.p_object, pBuffer, nSize, TRUE);
00680:         if (nRes == -1)
```

```
12909: HandleInvoke(RTMP *r, const char *body, unsigned int nBodySize)
```

```
12910: {
12911:     AMFObject obj;
12912:     AVal method;
12913:     double txn;
12914:     int ret = 0, nRes;
12915:     if (body[0] != 0x02) /* make sure it is a string method name we start with */
12916:     {
12917:         RTMP_Log(RTMP_LOGWARNING, "%s, Sanity failed. no string method in invoke packet",
12918:             __FUNCTION__);
12919:         return 0;
12920:     }
12921:
12922:     nRes = AMF_Decode(&obj, body, nBodySize, FALSE);
```

```
AMF_GetProp(AMFObject *obj, const AVal *name, int nIndex)
```

```
{
    if (nIndex >= 0)
    {
        if (nIndex < obj->o_num)
            return &obj->o_props[nIndex];
        else
        {
            int n;
            for (n = 0; n < obj->o_num; n++)
            {
                if (AVMATCH(&obj->o_props[n].p
                    return &obj->o_props[n];
            }

            return (AMFObjectProperty *) &AMFProp_Invalid;
        } ? end AMF_GetProp ?
    }
}
```

Crash

```
03104: else if (AVMATCH(&method, &av_onStatus))
```

```
03105: {
03106:     AMFObject obj2;
03107:     AVal code, level;
03108:     AMFProp_GetObject(AMF_GetProp(&obj, NULL, 3), &obj2);
03109:     AMFProp_GetString(AMF_GetProp(&obj2, &av_code, -1), &code);
03110:     AMFProp_GetString(AMF_GetProp(&obj2, &av_level, -1), &level);
03111: }
```

```
00347: AMFProp_GetObject(AMFObjectProperty *prop, AMFObject *obj)
```

```
00348: {
00349:     obj = prop->p_vu.p object;
00350: }
```

Windows平台下Ffmpeg验证结果：

```
D:\ffmpeg>ffmpeg.exe -i rtmp://127.0.0.1/vod/red5 -c copy dump2.flv
ffmpeg version N-67929-g5182a2a Copyright (c) 2000-2014 the FFmpeg developers
built on Nov 23 2014 22:01:49 with gcc 4.9.2 (GCC)
configuration: --enable-gpl --enable-version3 --disable-w32threads --enable-av
isynth --enable-bzlib --enable-fontconfig --enable-frei0r --enable-gnutls --enab
le-iconv --enable-libass --enable-libbluray --enable-libbs2b --enable-libcaca --
enable-libfreetype --enable-libgme --enable-libgsm --enable-libilbc --enable-lib
modplug --enable-libmp3lame --enable-libop
b --enable-libopenjpeg --enable-libopus --
r --enable-libsoxr --enable-libspeex --ena
able-libvidstab --enable-libvo-aacenc --en
--enable-libvpx --enable-libwavpack --ena
libx265 --enable-libxavs --enable-libxvid
libavutil      54. 15.100 / 54. 15.100
libavcodec     56. 13.100 / 56. 13.100
libavformat    56. 15.100 / 56. 15.100
libavdevice    56.  3.100 / 56.  3.100
libavfilter     5.  2.103 /  5.  2.103
libswscale     3.  1.101 /  3.  1.101
libswresample  1.  1.100 /  1.  1.100
libpostproc   53.  3.100 / 53.  3.100
HandShake: client signature does not match!
```

ffmpeg.exe - 应用程序错误

“0x013e123e” 指令引用的 “0x41711115” 内存。该内存不能为 “read”。

要终止程序，请单击“确定”。

要调试程序，请单击“取消”。

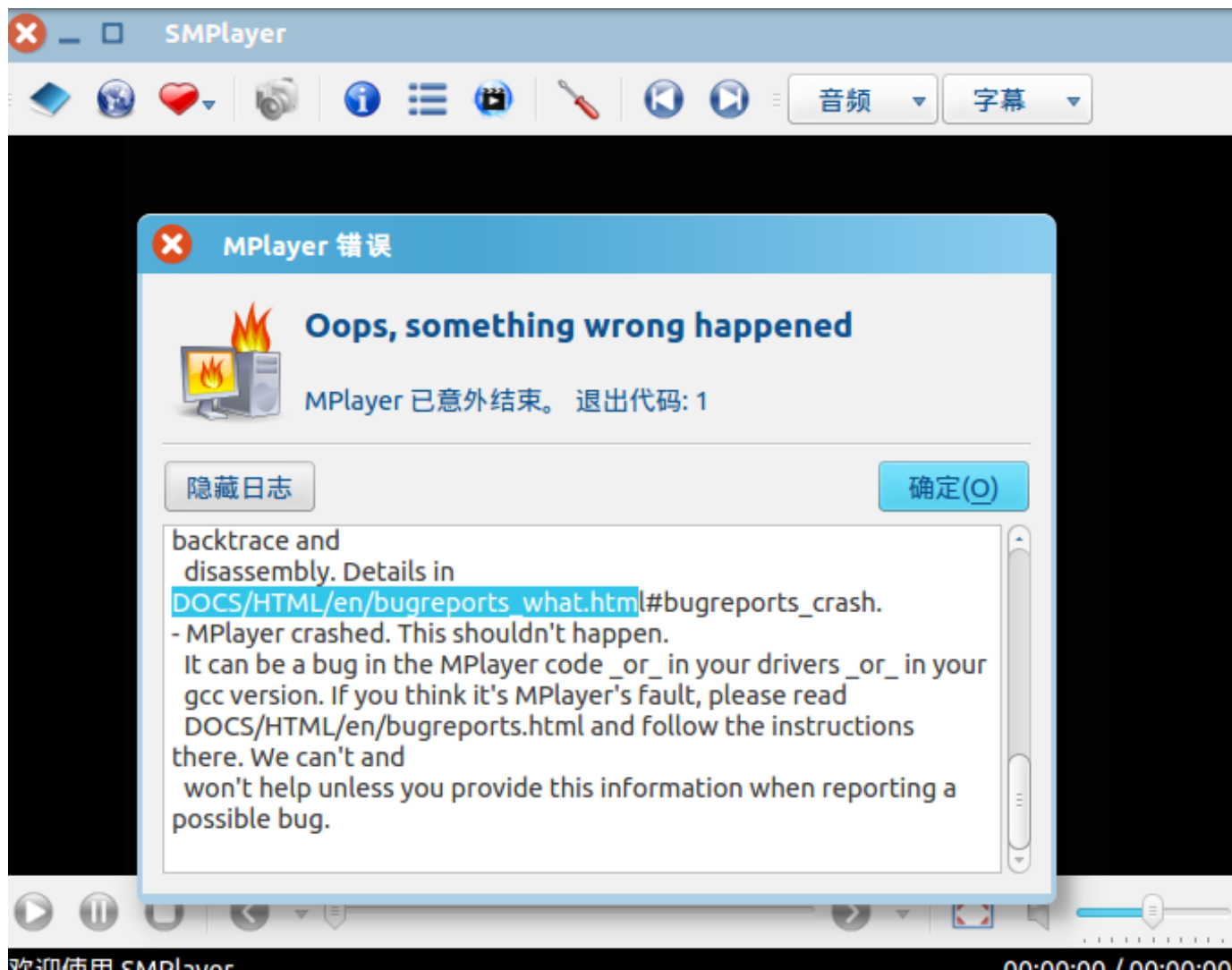
确定 取消

可以看到FFmpeg程序崩溃，并指出了对地址0x41711115的非法访问

Windows平台下SMPlayer验证结果：



Ubuntu自带播放器SMPlayer验证结果：



实例分析4—某开源分类系统硬编码敏感信息

```
22 String username="ma2@163.com";//发邮件的邮箱
23
24 private Message getMessage(){
25
26     Properties p=new Properties();
27     p.put("mail.smtp.protocol","smtp");
28     p.put("mail.smtp.host","smtp.163.com");
29     p.put("mail.smtp.port","25");
30     p.put("mail.smtp.auth","true");
31
32
33 String password="56021234";//该邮箱的密码
34 AuthorDTO auth=new AuthorDTO(username,password);
```

MORE.....

电子商务平台OFBiz__路径遍历：

```
372 public static String deletePreviewWatermarkImage(HttpServletRequest request, HttpServletResponse  
373     Map<String, ? extends Object> context = UtilGenerics.checkMap(request.getParameterMap())  
374     String imageServerPath = FlexibleStringExpander.expandString(UtilProperties.getPropertyVa  
375     String count = request.getParameter("count");  
376     File file = new File(imageServerPath + "/preview/" + "/previewImage" + count + ".jpg");  
377     file.delete();
```

博客系统solo__HTTP消息头注入：

```
253  
254     String destinationURL = httpRequest.getParameter(Common.GOTO);  
255  
256     if (Strings.isEmptyOrNull(destinationURL)) {  
257         destinationURL = "/";  
258     }  
259  
260     context.getResponse().sendRedirect(destinationURL);  
261 }
```

医疗电子病历系统openmrs__资源注入：

```
115     String downloadURL = request.getParameter("downloadURL");  
116     if (downloadURL == null) {  
117         throw new MalformedURLException("Couldn't download mo  
118     }  
119     String fileName = downloadURL.substring(downloadURL.lastIn  
120     final URL url = new URL(downloadURL);  
121     inputStream = ModuleUtil.getURLStream(url);
```

内容管理系统OpenCms __命令注入：

```
1490     final String ID= "runUserCommandRemotely "+id+" ";
1491     util.DEBUG(ID+"Execute '"+ command +"' on '"+ host +"' as " + testUser);
1492
1493     String localCommand = remoteShell + " "
1494         + "-l " + testUser + " " + host + " "
1495         + command
1496         ;
1497
1498     String output = "";
1499     try {
1500         Runtime rt = Runtime.getRuntime();
1501         Process proc = rt.exec(localCommand);
1502         output = processOutput(ID, proc);
1503         int exitVal = proc.waitFor();
1504         util.DEBUG("ExitValue: " + exitVal);
1505     } catch (Throwable t) {
1506         t.printStackTrace();
1507     }
```

手机聊天系统PushTalk__SQL注入：

```
233     String sql = "SELECT * from user where name = '" + name + "'";
234     Statement st = null;
235     User user = null;
236     try {
237         st = getStatement();
238         ResultSet rs = st.executeQuery(sql);
```

软件项目管理和问题管理Cynthia__反射型XSS：

```
18     <%
19         String targetUrl = request.getParameter("targetUrl");
20         targetUrl = CynthiaUtil.isNull(targetUrl) ? "" : targetUrl;
21         String loginErrorInfo = (String)request.getSession().getAttribute(
22             loginErrorInfo = loginErrorInfo == null ? "" : loginErrorInfo;
23     %>
24
25     <body onload="initUser('<%=targetUrl%>', '<%=loginErrorInfo %>');">
26     <div class="container-fluid" style="margin-top:150px;">
```

工作流和协作服务引擎Oozie__LDAP注入：

```
97     env.put(Context.SECURITY_CREDENTIALS, password);
98     DirContext ctx = new InitialDirContext(env);
99     if (ctx != null) {
100         //
```

详细描述	函数关系
文件路径	描述
[1]LDAPLoginServlet.java	new InitialDirContext(env)
[2]LDAPLoginServlet.java	env.put(Context.SECURITY_CREDENTIALS,password)
[3>LoginServlet.java	verifyPassword(username,password)
[4>LoginServlet.java	password=req.getParameter(PASSWORD)

内容管理系统infoglue__XPath注入：

```
2287     NodeList an1 = org.apache.xpath.XPathAPI.selectNodeList(document.getDocumentElement(), componentPropertyXPath);
2288     if(an1.getLength() > 0)
2289         //
```

详细描述	函数关系	
文件路径	描述	跟踪行号
[1]ViewSiteNodePageComponentsAction.java org.apache.xpath.XPathAPI.selectNodeList(document.getDocumentElement(2287		
[2]ViewSiteNodePageComponentsAction.java	componentPropertyXPath="//component[@id=" + this.componentId +	2285
[3]ViewSiteNodePageComponentsAction.java	propertyName=this.getRequest().getParameter("propertyName")	2272

数据分发平台Hazelcast__不恰当资源释放：

```
274     try {
275         HttpURLConnection httpURLConnection = (HttpURLConnection) (new URL(url)).openConnection();
276         BufferedReader rd = new BufferedReader(new InputStreamReader(httpURLConnection.getInputStream()));
277         StringBuilder data = new StringBuilder(150);
278         String line;
279         while ((line = rd.readLine()) != null) data.append(line);
280         rd.close();
281         result = data.toString();
282         httpURLConnection.disconnect();
283     } catch (Exception e) {
```

主要内容

- 1、开源软件安全事件带来的思考
- 2、开源项目检测计划和实例分析
- 3、软件代码安全解决之道

软件安全生产中的问题

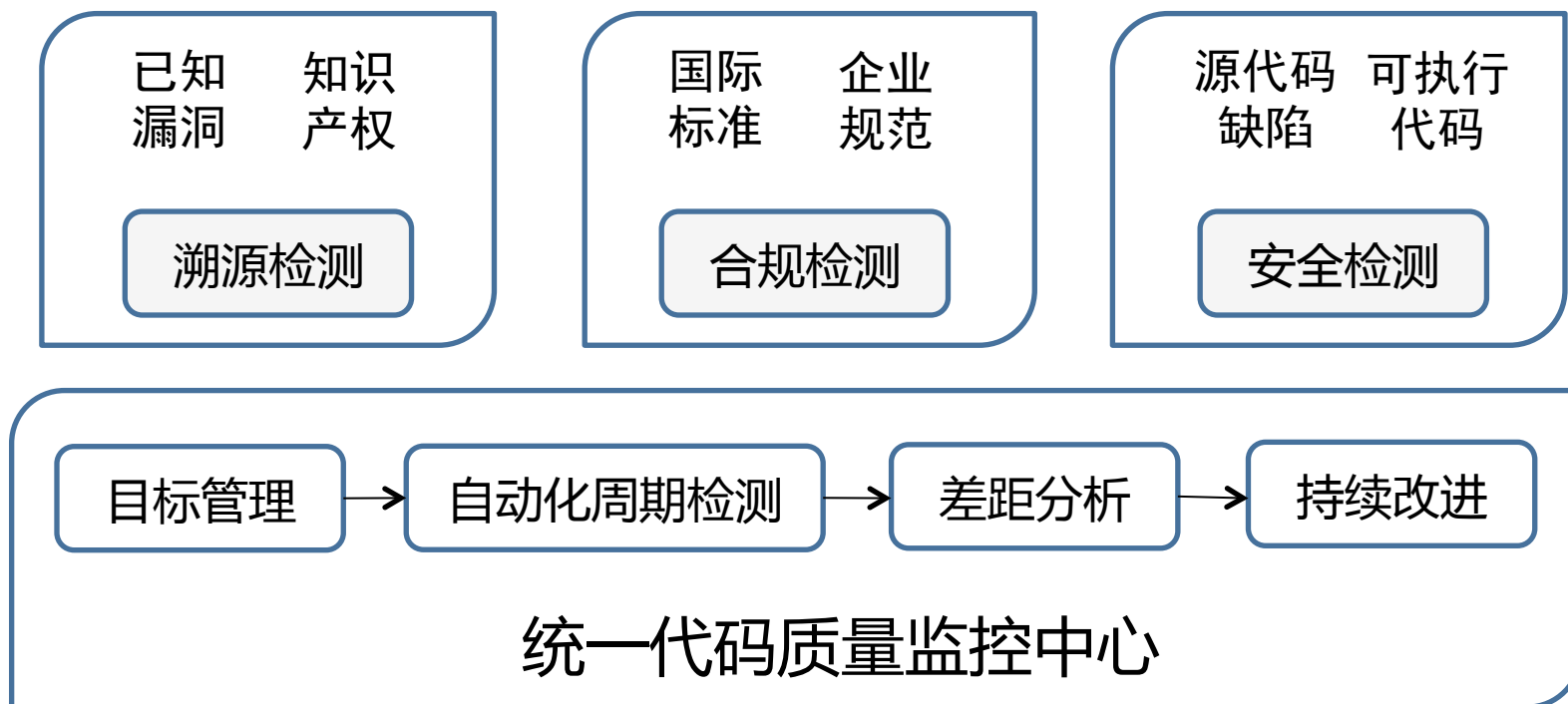
软件原材料（开源软件）是否安全

软件开发过程中是否遵守安全开发规范

软件成品中是否存在缺陷和漏洞

软件开发时有没有统一的安全管理策略

软件安全生产的解决办法





中国互联网安全大会



360互联网安全中心

Thanks!